执行摘要

HyperOS 预装组件数据采集与上报

- **对象**：一台 Xiaomi HyperOS 3.0（Android 16）设备
- **方法**：静态反编译 + 运行时数据库取证 + 真机抓包 + 解密验证
- **日期**：2026-11-08

结论

设备上存在 **两套运营商终端管理（DM）客户端、一套电信自动注册组件、一套系统遥测组件、一套本地反诈数据库**，以及**系统包管理器的安装上报链路**。联通 DM 有明文抓包/解密证据；移动 DM 有 TLS 连接与本地表结构证据，字段级上报未解密确认；反诈数据库只写本地，未发现上传。

关键发现

#	发现
1	联通 DM `com.mobiletools.systemhelper` 经 **明文 HTTP 18080** 上报设备/SIM 标识、经纬度、基站、WiFi 与 App 清单
2	移动 DM `com.miui.dmregservice` 的代码/表结构支持 App 清单、SIM 标识、基站/WiFi、流量等采集/上报；本次 HTTPS 未解密，字段级内容未确认。公开快照中 `app_info_*` 447 行，network/traffic/WiFi/Bluetooth/battery 表 0 行
3	加密为 `AES-128-ECB`，**`key = MD5(明文)`**；`sign` 是 RSA-1024 包裹的 key
4	两套 DM 的导出组件在静态检查中未见调用方校验，存在**潜在未授权调用面**；普通第三方应用的实际可达性与重定向效果尚未用最小 PoC 验证
5	反诈库（截屏时间/安装/通话）仅本地；AI 通话防诈开关关闭
6	AI 防诈：**普通未知号码电话触发语音检测；视频录屏入口是微信/QQ 特定通话 Activity**，受能力位 /`isUsingCamera` 约束。视频路径为录 3 秒 → 上传检测 → 未命中隔 2 秒再录，命中弹警告并停止；申请整

#	发现
	屏镜像但受 `FLAG_SECURE` 限制，敏感界面实际可录范围未实测。当前开关 0、无活跃 MediaProjection、无 clip；截图仅记时间戳
7	包管理器 `com.miui.packageinstaller` **打开安装界面即上报包名/设备信息**；**安装与取消都会**向 `/avl/upload` 上传元数据；APK 加密片段/TLSH 为代码能力；GuardProvider 云查有服务日志及 DNS/SNI 证据，字段为代码级；实测风险应用要求单次安装授权，取消仍上报，授权后安装成功（`installCnt=1`）；本次窗口内未观察到 `/virus/localResult/report`，不证明从未生成待传文件
8	电信自动注册 `com.xiaomi.registration` 采集 MEID/IMEI/IMSI/ICCID/MAC/Cell ID；偏好项与代码表明曾成功注册，基于当前 SIM/分支条件推断可在移动卡+WiFi 下完成，未捕获该次请求/响应

实测结果

- **B/R/A 解密成功**：B（设备信息）、R（信号历史，100 条）、A（App 清单，169 个 App）；A 的 200 成功样本不落队列
- 服务器限流：同一时段 `200` 与 `429` 混合；观察到重复密文请求及成功状态码，但服务端是否做重放检测、去重或幂等处理未验证
- 两套 DM 的预装清单和 App 表有本地数据；移动 DM 的 network/traffic/WiFi/Bluetooth/battery 本次快照为 0 行，未取到这些字段的本次样本
- 静态检查未发现两套 DM 的 push/网络监听入口；已知触发源为闹钟、系统广播、本地导出组件、运营商 SMS/STK（间接）；普通应用实际可达性待 PoC
- 采集与上报频率不同：位置/基站默认 **30 分钟**调度写入本地；实测 R 样本 100 条跨度 55.57h，83/99 个间隔为 30 分钟；信号历史默认 **12 小时**、App 清单 **24 小时**上报一次
- 包管理器：安装成功与取消均有 `/avl/upload` 日志（`installCnt=1/0`）；per-app 云控路径有端点日志，GuardProvider 云查有服务日志及 DNS/SNI 证据。风险样本 Avl 命中 `Risk/Android.R_Cont.Porn`，完成单次授权后安装成功，取消也上传元数据。检查时威胁报告目录为空、窗口内未观察到报告请求，不能排除文件曾入队后上传或删除；两条 `adb install`/`pm install` 测试窗口内未出现同一 UI `/avl/upload`，不代表其他后台/延迟链路均无上报。已捕获全局配置响应（16 条禁装规则、94 条离线白名单、一键授权参数）。

风险与建议

维度	评级	建议
隐私采集	高	关闭 `operator_service_improve_plan`；优先停用/备份，不建议直接整库删除；按需禁用两个包
传输安全	中高	厂商改用 HTTPS + AEAD，停止 `key=MD5(明文)`，RSA ≥ 2048
用户可控性	低	提供可见开关、数据清单与删除入口
本地攻击面	中	导出组件增加签名权限与调用方校验
安装上报	中高	打开/取消均上报；云端可控 APK 片段；风险提示页同屏广告；建议告知同意、取消停止上传、片段上传单独授权

> 用户侧一条命令即可关闭联通 DM 总闸： `settings put secure operator_service_improve_plan 0` 注意：该开关**只控制联通 DM**，移动 DM 由云端开关单独控制。
>
> 移动 DM 需整包禁用：`pm disable-user --user 0 com.miui.dmregservice`。

证据

- 公开报告：`docs/report_public.md`（v2）
- 证据清单：`evidence/MANIFEST.md`（SHA-256）
- 抓包：仅本地 `private/pcap/`（不入库）；反编译关键类：`evidence/decompiled/key/`
- 包管理器脱敏日志：`evidence/redacted/package_installer_upload.log`

声明

本报告基于单台设备、单次取证；组件均为系统预装、Xiaomi 平台签名。报告关注采集范围、加密方式与用户可控性，不推断其主观意图。